## Table 1: General-Purpose Open-Source SBOM Generators

| Tool Name | Provider | Ecosystems Covered | Usage Rights | Specific Provider Claims | Acquisition Method |
|---|---|---|---|---|---|
| **Syft** | Anchore | Containers (OCI, Docker, Singularity), Archives, Filesystems | Apache-2.0 | "If it's there, we'll tell you about it." Deep discovery of both direct and transitive dependencies; optimized for Grype integration. | Shell script (curl \| sh), Homebrew, Docker image, binaries[16]. |
| **cdxgen** | OWASP Foundation / CycloneDX | Polyglot source code, Containers, CBOM, OBOM, SaaSBOM | Apache-2.0 | Universal polyglot CLI; highest recall for application and source SBOMs by integrating with package managers; emits advanced CycloneDX 1.6/1.7. | NPM (npm install -g @cyclonedx/cdxgen)[19]. |
| **Trivy** | Aqua Security | Containers, Kubernetes clusters, Git repos, | Apache-2.0 | Fast, all-in-one open-source security | Binaries, APT/YUM, Homebrew, Docker |

| | | | | | |
|---|---|---|---|---|---|
| | | Virtual Machines | | scanner; seamlessly integrates SBOM generation with real-time CVE scanning in CI/CD. | image[22]. |
| **Microsoft SBOM Tool** | Microsoft | Multi-ecosystem (NPM, NuGet, PyPI, Maven, Rust), Docker images | MIT | Highly scalable, enterprise-ready; seamlessly integrates with ClearlyDefined API for automated, deep license information. | GitHub releases, GitHub Actions, Azure DevOps tasks[24]. |
| **spdx-sbom-generator** | OpenSBOM / SPDX Community | Go, NPM, Python, Ruby, PHP, Rust, Java (via current package managers) | Apache-2.0 | Automatically determines the package manager; aligns with NTIA minimum elements and SPDX v2.2 specification. | Go compilation, Docker (docker pull spdx/spdx-sbom-generator)[26]. |
| **kubernetes** | Kubernetes | Go-centric | Apache-2.0 | Authoritativ | Go |

| | | | | | |
|---|---|---|---|---|---|
| **-sigs/bom** | SIG Release | codebases, OCI containers, filesystems | | e tool for generating the BOM of Kubernetes releases; natively handles Go module complexities and OCI image parsing. | installation (go install), GitHub releases[25]. |
| **Docker BuildKit (SBOM Attestations)** | Docker | OCI Container Images during the build process | Apache-2.0 | Embeds the SBOM directly into the container's OCI image index as an in-toto attestation at the exact moment of the image build. | Built into Docker CLI (docker buildx build --sbom=true)[14]. |
| **GitHub Self-Service SBOMs** | GitHub | All repositories hosted on GitHub with dependency graph support | Free to use on platform | Frictionless, one-click mechanism to export NTIA-compliant SPDX 2.3 SBOMs natively from the cloud UI or Actions. | Natively accessible via GitHub Web UI (Insights tab)[25]. |
| **Tern** | Linux Foundation | Container images, | BSD-2-Clause | Layer-by-layer | Python pip install tern, |

| | | | | | |
|---|---|---|---|---|---|
| | | Dockerfiles | | container inspection; provides granular attribution for exactly which layer introduced a specific component. | Docker image[6]. |
| **FOSSology** | Linux Foundation / FOSSology | Source code repositories | GPL-2.0 | Deep open-source license scanning and compliance engine; analyzes texts, copyrights, and exports compliant SBOMs. | Source compilation, Docker image[33]. |
| **CaPyCli** | Siemens | Java, JavaScript, Python | MIT | Python CLI that generates, compares, merges, and converts CycloneDX SBOMs; maps components to a SW360 database. | Open source repository distribution[7]. |

# 4. Ecosystem-Specific Native Plugins

## Table 2: CycloneDX Language-Specific Generation Tools

| Tool Name | Ecosystem | Usage Rights | Specific Claims & Mechanisms | Acquisition Method |
|---|---|---|---|---|
| **cyclonedx-maven-plugin** | Java (Maven) | Apache-2.0 | Hooks directly into the Java build lifecycle. Eliminates false positives by interrogating the JVM's actual dependency tree during compilation. | Maven pom.xml inclusion (mvn org.cyclonedx:cyclonedx-maven-plugin:makeAggregateBom)[6]. |
| **cyclonedx-gradle-plugin** | Java (Gradle) | Apache-2.0 | Provides deterministic Gradle dependency resolution, natively outputting CycloneDX JSON/XML. | Gradle build.gradle plugin inclusion (./gradlew cyclonedxBom)[5]. |
| **@cyclonedx/cyclonedx-npm** | Node.js / JavaScript | Apache-2.0 | Respects complex NPM hoisting mechanisms. Analyzes package.json and lockfiles to output structurally accurate graphs. | NPM installation (npm install -g @cyclonedx/cyclonedx-npm)[3][9]. |

| | | | | |
|---|---|---|---|---|
| **cyclonedx-bom (CLI: cyclonedx-py)** | Python | Apache-2.0 | Analyzes requirements.txt, Poetry lockfiles, or live virtual environments. Extracts license texts directly from installed modules. | PIP installation (pip install cyclonedx-bom)[5]. |
| **cyclonedx-gomod** | Go | Apache-2.0 | Bypasses heuristic guessing by extracting precise module dependencies directly from the go.mod and Go build graph. | Go compilation (go install github.com/CycloneDX/cyclonedx-gomod/cmd/cyclonedx-gomod@latest)[5]. |
| **cargo-cyclonedx** | Rust | Apache-2.0 | Operates natively within the Cargo ecosystem to resolve dependencies and build configurations for compiled Rust binaries. | Cargo installation (cargo install cargo-cyclonedx)[5]. |
| **dotnet-CycloneDX** | .NET (C#) | Apache-2.0 | Integrates with NuGet to traverse solution files and project dependencies, | .NET CLI (dotnet tool install --global CycloneDX)[5]. |

| | | | | |
|---|---|---|---|---|
| | | | generating high-fidelity component lists. | |

**Analytical Context of Native Plugins:** Strategic utilization of these plugins requires integration deep into the CI/CD pipeline rather than running a passive post-build scan. While they demand a higher initial configuration burden, they yield mathematically deterministic results regarding application-level dependencies[13]. For example, the cyclonedx-maven-plugin executes within the context of the Maven reactor, allowing it to differentiate between test, provided, and compile scopes—a distinction that general-purpose static file scanners often fail to discern, thereby injecting false positives into the resulting SBOM[6].

# 5. Commercial and Enterprise SBOM Management Platforms

## Table 3: Commercial and Enterprise SBOM Platforms

| Tool / Platform | Provider | Ecosystems Covered | Licensing Model | Specific Provider Claims | Acquisition Method |
|---|---|---|---|---|---|
| **Snyk (Snyk CLI)** | Snyk | Source code, Containers, IaC, AI models | Commercial (Freemium tier) | Developer-first "shift-left" security; automatically embeds license metadata alongside security vulnerabilities directly into the generated SBOM. | NPM install (npm install -g snyk), API authentication[2]. |
| **FOSSA** | FOSSA | Source code, broad language | Commercial (Freemium | Supreme open-source license | SaaS subscription, FOSSA |

| | | | | | |
|---|---|---|---|---|---|
| | | ecosystems, manifests | tier) | compliance; provides audit-grade reporting and snippet analysis to detect illegally pasted, unmanaged code. | CLI[47]. |
| **Black Duck Binary Analysis** | Synopsys / Revenera | Executable binaries, firmware, containers (Intel, ARM, MIPS, PowerPC) | Commercial | "No Source Code Required." Parses the exact binary shipped to the customer; detects statically linked libraries and information leakage. | Enterprise software subscription[50]. |
| **Sonatype Nexus Lifecycle** | Sonatype | Major build systems, container registries, AWS | Commercial | Enforces custom security and license policies throughout the CI/CD pipeline; features the industry's largest proprietary vulnerability | AWS Marketplace, enterprise subscription[53]. |

| | | | | | |
|---|---|---|---|---|---|
| | | | | catalog. | |
| **Finite State** | Finite State | IoT embedded systems, automotive firmware, OT devices | Commercial | Next-generation platform for connected devices; capable of unpacking over 90 complex firmware formats (SquashFS, UBI, CramFS). | Enterprise SaaS subscription[6]. |
| **Mend.io** | Mend.io | Multi-language software projects, AI-BOM generation | Commercial | Continuous inventory tracking; automatically satisfies license obligations and opens issues for external resource usage. | Enterprise subscription[57]. |
| **OX Security** | OX Security | Pipeline tools, cloud-native deployments | Commercial (Freemium tier) | Generates a Pipeline Bill of Materials (PBOM), connecting each software component directly to the CI/CD | Enterprise SaaS subscription[2]. |

| | | | | | |
|---|---|---|---|---|---|
| | | | | pipeline that built it. | |
| **CAST SBOM Manager** | CAST | Source code analysis | Freemium | Automates creation and maintenance of SBOMs; adds vulnerability insights and exports to Excel/Word. | Freemium tier available (up to 25 SBOMs)[7]. |
| **Advanced Installer** | Advanced Installer | Windows installer packages (.msi, .exe) | Commercial | Automatically generates SPDX SBOMs for software packages during the installer creation process. | Commercial software license[24]. |
| **Cyberwatch** | Cyberwatch | General IT assets, continuous vulnerability management | Commercial | Consumes SBOMs and directly maps them against live vulnerability databases for French and European regulatory compliance. | Commercial subscription[26]. |

| | | | | | |
|---|---|---|---|---|---|
| **Cybeats (sbomgen)** | Cybeats | General software, CSV/Excel conversion | Commercial | Converts non-standard formats (CSV/Excel) to CycloneDX and generates specialized Cryptographic BOMs (CBOMs). | Enterprise SaaS subscription[60]. |